ICT2217

Network Security

Lab 1.5 Notes:

DHCP Attacks and Defense

Lab Exercise 1.5

1–4

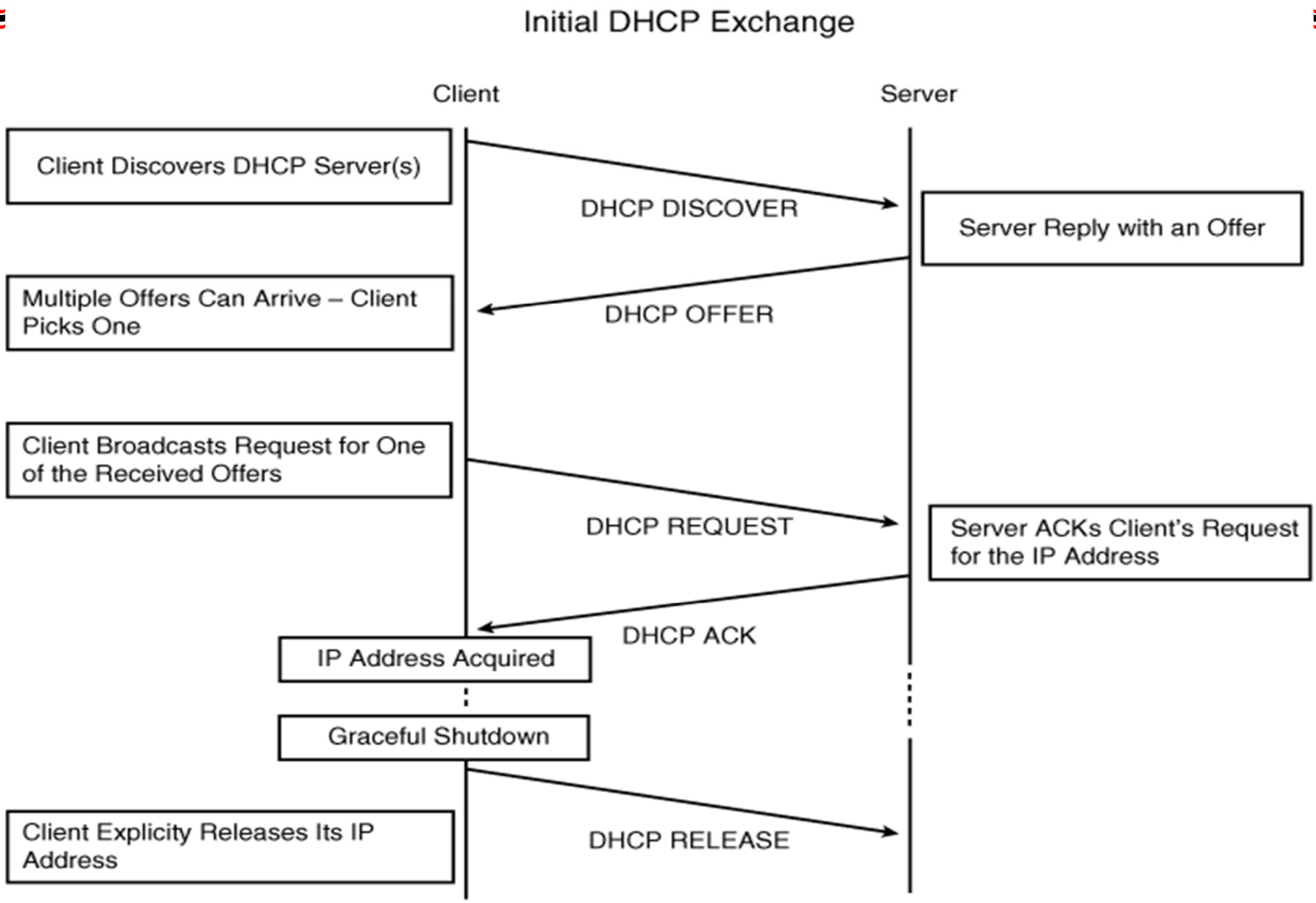
DHCP starvation and DHCP server spoofing attacks, which can lead to DNS server spoofing and website spoofing attacks

5

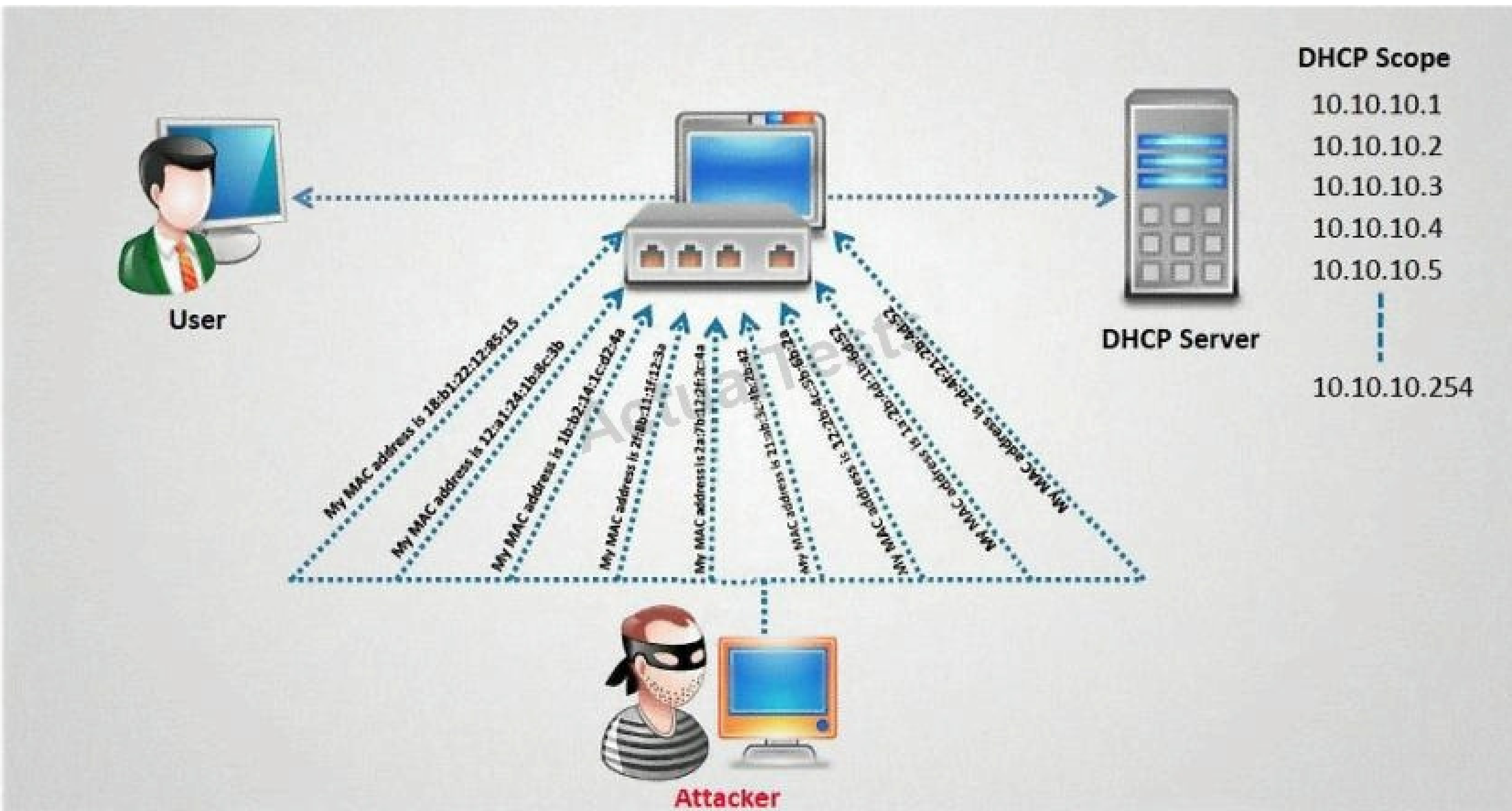
Defense:

- Configure DHCP snooping in switches

In ICT1013, you have learned DHCP (Dynamic Host Control Protocol) for hosts to automatically obtain IP address, default gateway, DNS, etc. in order to function.



Unfortunately, DHCP has no security! An obvious attack is starvation/exhaustion/DoS attack where an attacker generates many DHCP Discover messages to seize all IP addresses.

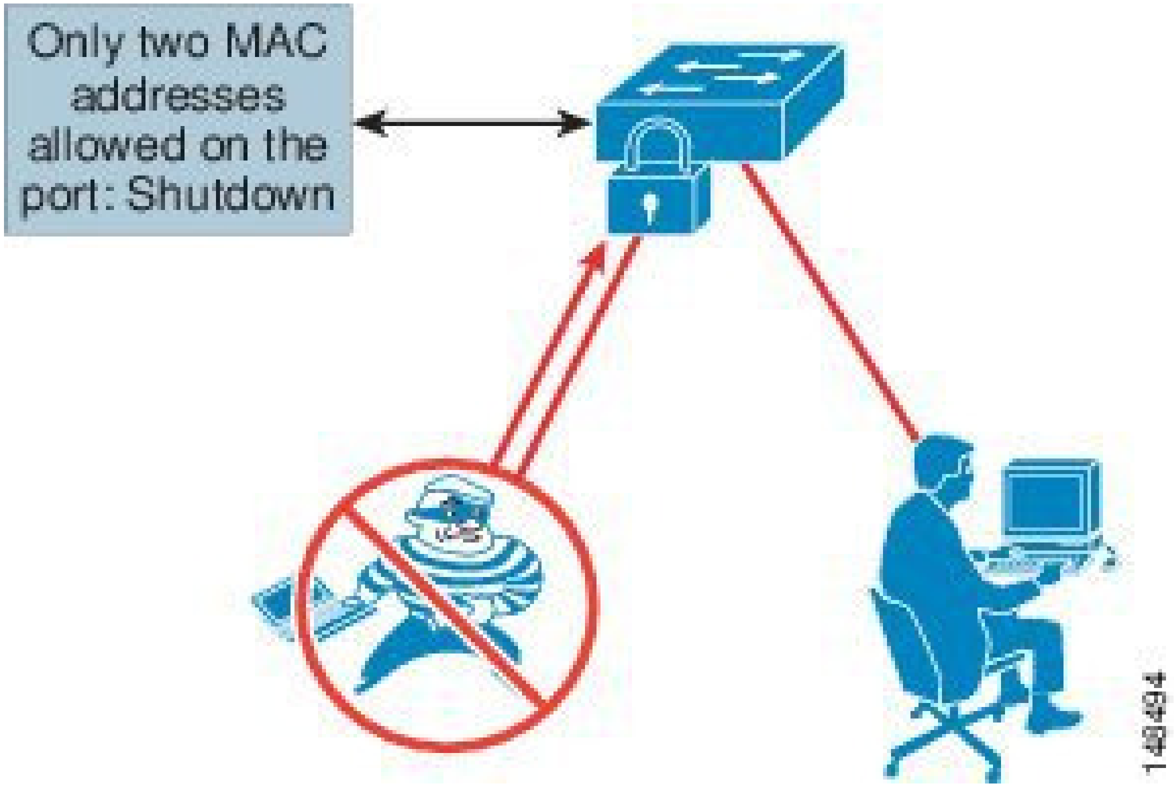


An example of conducting DHCP starvation attack using DHCPig in Kali Linux.

```
kali@kali: ~
File  Actions  Edit  View  Help

┌──(kali㉿kali)-[~]
└─$ sudo dhcpig eth0
[ -- ] [INFO] - using interface eth0
[DBG ] Thread 0 - (Sniffer) READY
[DBG ] Thread 1 - (Sender) READY
[——>] DHCP_Discover
[——>] DHCP_Discover
[——>] DHCP_Discover
[——>] DHCP_Discover
[——>] DHCP_Discover
[ ?? ]          waiting for first DHCP Server response
[——>] DHCP_Discover
[——>] DHCP_Discover
[——>] DHCP_Discover
[——>] DHCP_Discover
[——>] DHCP_Discover
[ ?? ]          waiting for first DHCP Server response
[——>] DHCP_Discover
[——>] DHCP_Discover
[——>] DHCP_Discover
[——>] DHCP_Discover
[ ?? ]          waiting for first DHCP Server response
[ -- ] timeout waiting on dhcp packet count 1
[——>] DHCP_Discover
[——>] DHCP_Discover
[——>] DHCP_Discover
```

Do you think Port Security is an effective defense to counter DHCP starvation attack?

Port Security limits the MAC addresses allowed on a port, which can prevent an attacker from sending many DHCP Discover messages with different MAC addresses.



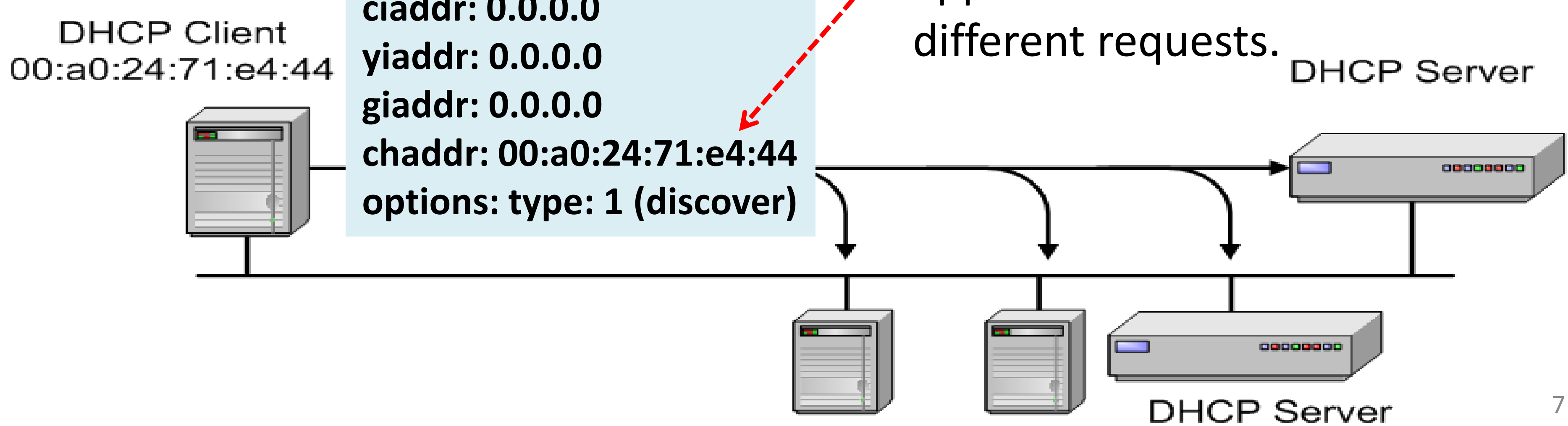
Unfortunately, an attacker can still generate many DHCPDiscover messages without violating Port Security as follow: (This shows why you need to know details!)

Remember DHCP is at application layer, i.e. the lower layers are removed by the OS before DHCP server receives the final DHCP message.

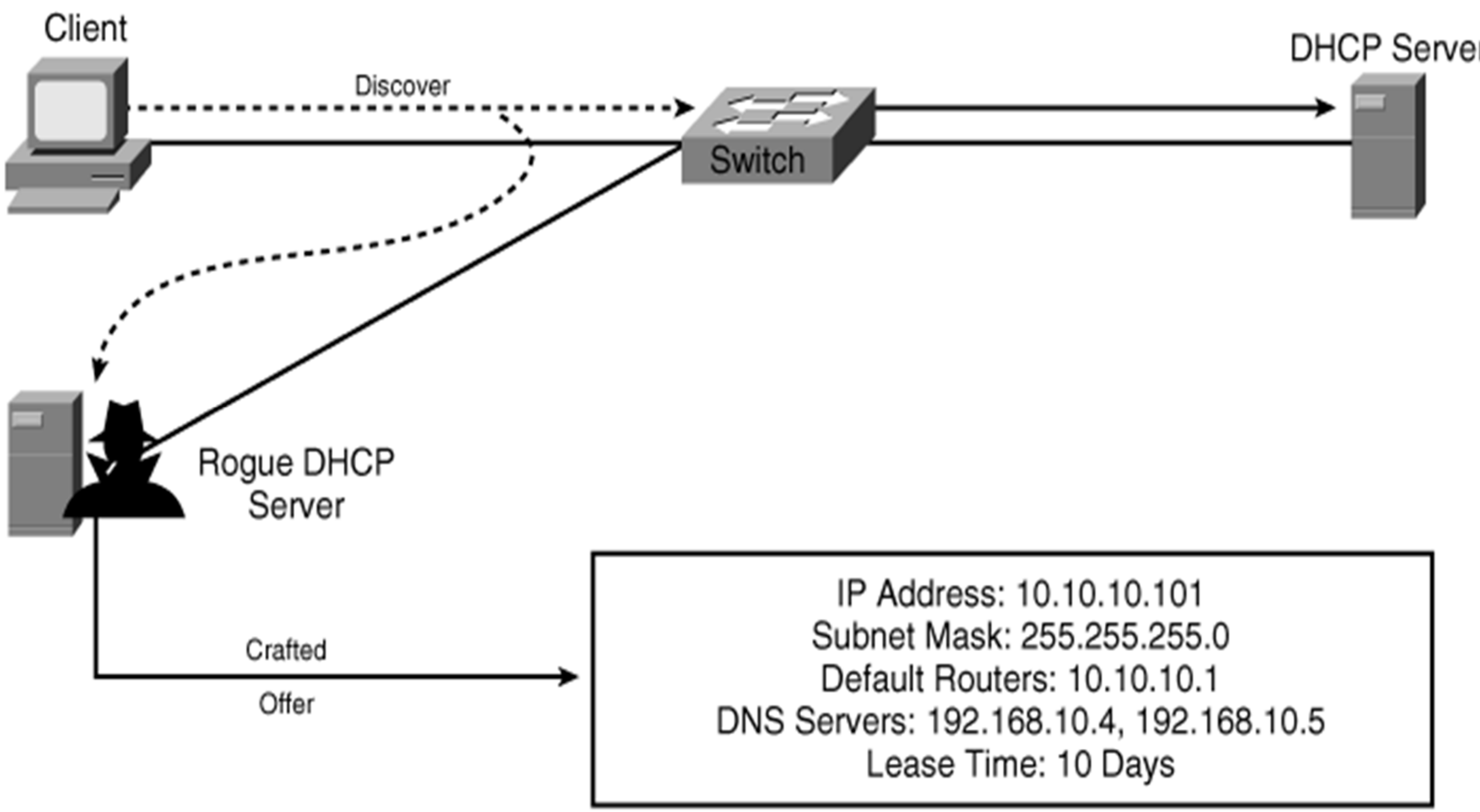
MAC	**src: 00:a0:24:71:e4:44** **dest: FF:FF:FF:FF:FF:FF**
IP/UDP	**src: 0.0.0.0:68** **dest: 255.255.255.255:67**
DHCP	**code: 1 (request)** **trans ID: 654** **ciaddr: 0.0.0.0** **yiaddr: 0.0.0.0** **giaddr: 0.0.0.0** **chaddr: 00:a0:24:71:e4:44** **options: type: 1 (discover)**

Fixed source MAC, no violation of Port Security.

Random source MAC, which appears to DHCP server as different requests.



After DHCP starvation attack, an attacker may follow up with DHCP server spoofing attack which is to set up a rogue DHCP server to respond to users DHCP messages.



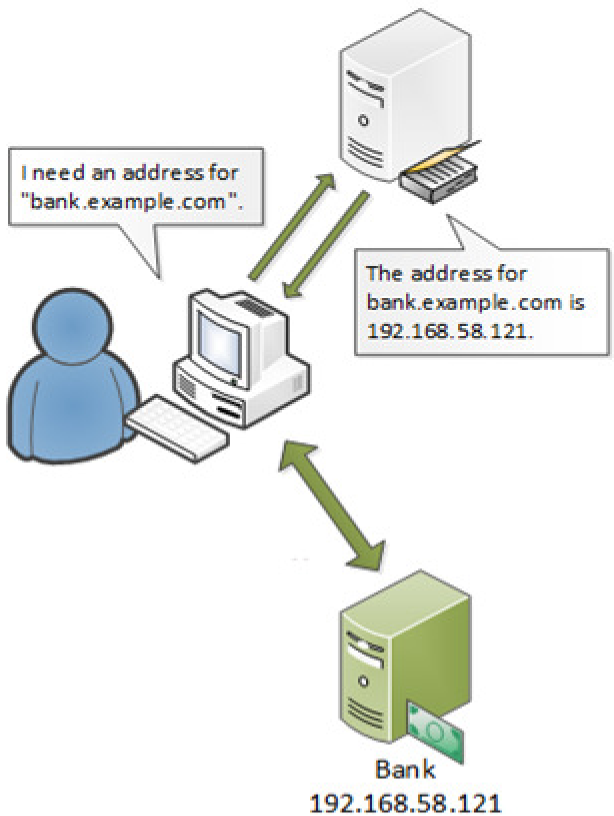
The Metasploit tool in Kali Linux has a DHCP module which can be used to run a rogue DHCP server.

```
┌──(kali㉿kali)-[~]
└─$ msfconsole

# cowsay++
 ____________
< metasploit >
 ------------
       \   ,__,
        \  (oo)____
           (__)    )\
              ||--|| *


       =[ metasploit v6.0.30-dev
+ -- --=[ 2099 exploits - 1129 auxiliary - 3
+ -- --=[ 592 payloads - 45 encoders - 10 no
+ -- --=[ 7 evasion

Metasploit tip: Search can apply complex fil
search cve:2009 type:exploit, see all the fi
with help search

msf6 > use auxiliary/server/dhcp
msf6 auxiliary(server/dhcp) >
```

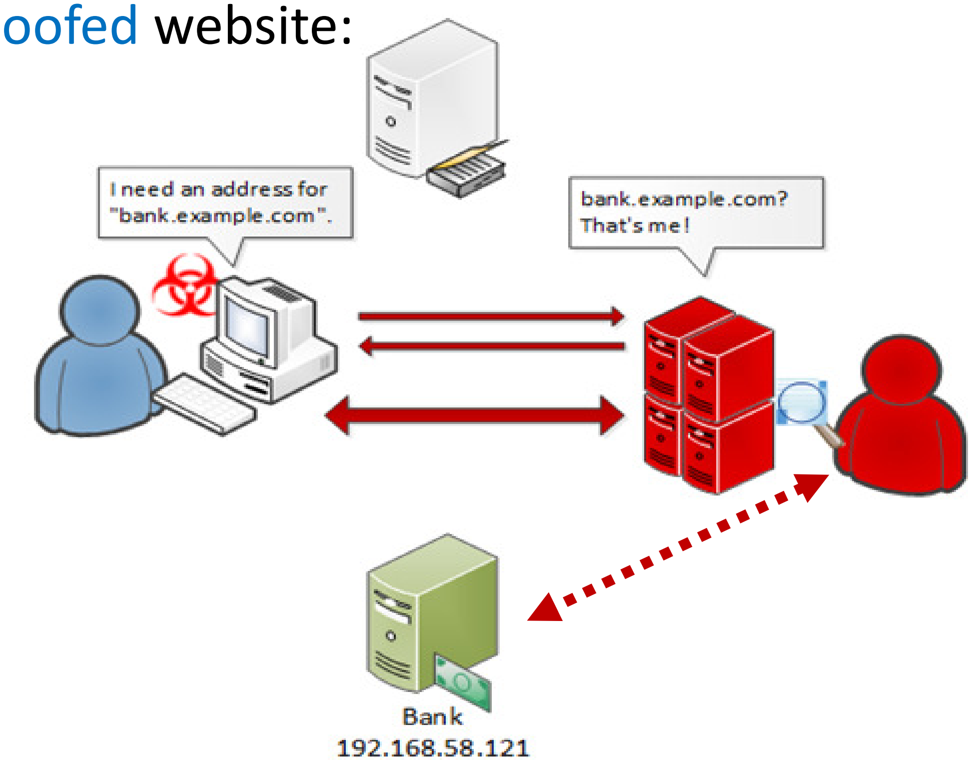
```
msf6 > use auxiliary/server/dhcp
msf6 auxiliary(server/dhcp) > set SRVHOST 192.168.1.11
SRVHOST => 192.168.1.11
msf6 auxiliary(server/dhcp) > set NETMASK 255.255.255.0
NETMASK => 255.255.255.0
msf6 auxiliary(server/dhcp) > set DHCPIPSTART 192.168.1.100
DHCPIPSTART => 192.168.1.100
msf6 auxiliary(server/dhcp) > set DHCPIPEND 192.168.1.199
DHCPIPEND => 192.168.1.199
msf6 auxiliary(server/dhcp) > set ROUTER 192.168.1.11
ROUTER => 192.168.1.11
msf6 auxiliary(server/dhcp) > set DNSSERVER 192.168.1.11
DNSSERVER => 192.168.1.11
msf6 auxiliary(server/dhcp) > show options

Module options (auxiliary/server/dhcp):

   Name         Current Setting  Required  Description
   ----         ---------------  --------  -----------
   BROADCAST                     no        The broadcast address to send to
   DHCPIPEND    192.168.1.199    no        The last IP to give out
   DHCPIPSTART  192.168.1.100    no        The first IP to give out
   DNSSERVER    192.168.1.11     no        The DNS server IP address
   DOMAINNAME                    no        The optional domain name to assign
   FILENAME                      no        The optional filename of a tftp bo
ot server
   HOSTNAME                      no        The optional hostname to assign
   HOSTSTART                     no        The optional host integer counter
   NETMASK      255.255.255.0    yes       The netmask of the local subnet
   ROUTER       192.168.1.11     no        The router IP address
   SRVHOST      192.168.1.11     yes       The IP of the DHCP server


Auxiliary action:

   Name     Description
   ----     -----------
   Service  Run DHCP server


msf6 auxiliary(server/dhcp) > run
```

With DHCP server spoofing attack, an attacker can now easily direct users to rogue DNS server to mistranslate domain name to IP address to lead them to the spoofed website!

Before attack:



After DHCP server spoofing attack directing user to rogue DNS server and then spoofed website:

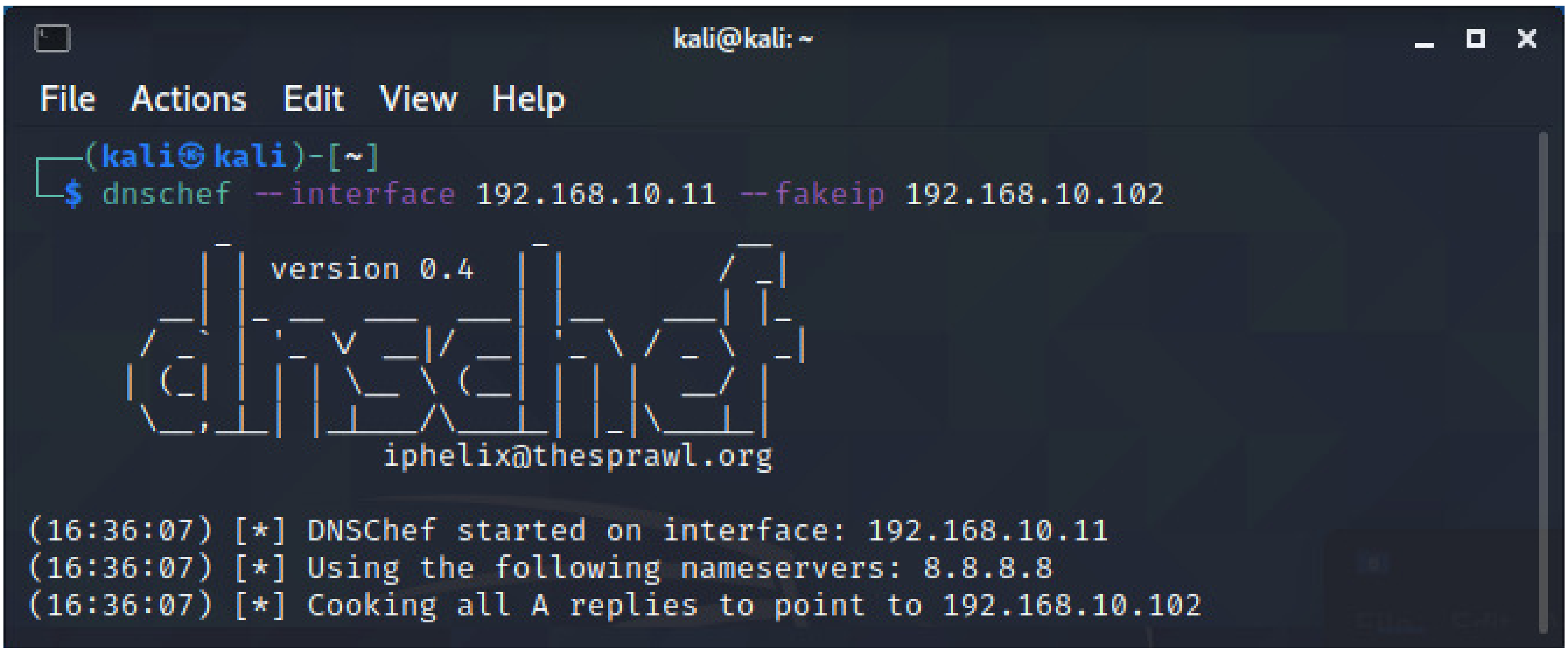


An attacker may then use the information obtained to masquerade as the authorized user to login to the real website!

The DNSChef tool in Kali Linux can be used to run the rogue DNS server.

Refer to *https://www.kali.org/tools/dnschef* on dnschef usage

e.g.: To start DNS server to listen at interface 192.168.10.11 and mis-translating all DNS replies to attacker's fake IP address 192.168.10.102



To prevent DHCP starvation and spoofing attacks, a defence called DHCP snooping is developed which enables a switch to perform deep-packet inspections of higher layers.

Enable DHCP snooping in the switch and then specify the required VLANs as follows:

```
Switch(config)# ip dhcp snooping
Switch(config)# ip dhcp snooping vlan vlan-id [vlan-id]
```

Configure DHCP snooping MAC address verification to verify layer 2 source MAC matches application layer DHCP client hardware address (chaddr), and drop if different.

```
Switch(config)# ip dhcp snooping verify mac-address
```

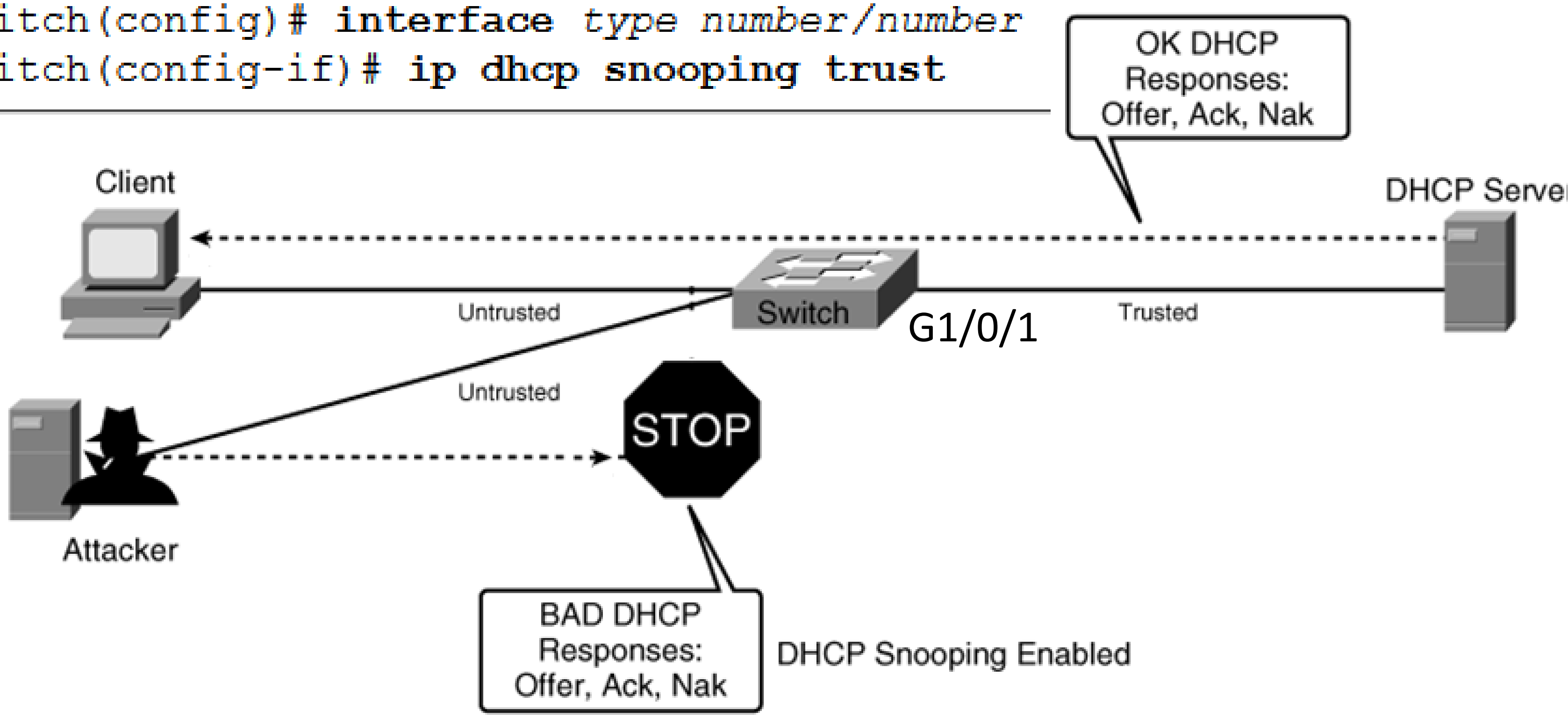
For each port, DHCP snooping rate-limiting (from 1 – 2048 DHCP pps) can also be configured. If exceeded, the port is put into err-disabled state.

```
Switch(config)# interface type number/number
Switch(config-if)# ip dhcp snooping limit rate rate
```

When DHCP snooping is enabled, all ports are by default untrusted which will not allow DHCP Offer and DHCP Ack messages, thus making it impossible to run rogue DHCP server

To support DHCP servers, the ports connected to the authorized DHCP servers must be manually configured to be trusted as follows:

```
Switch(config)# interface type number/number
Switch(config-if)# ip dhcp snooping trust
```



An example of configuring DHCP snooping on a switch and verifying the status:

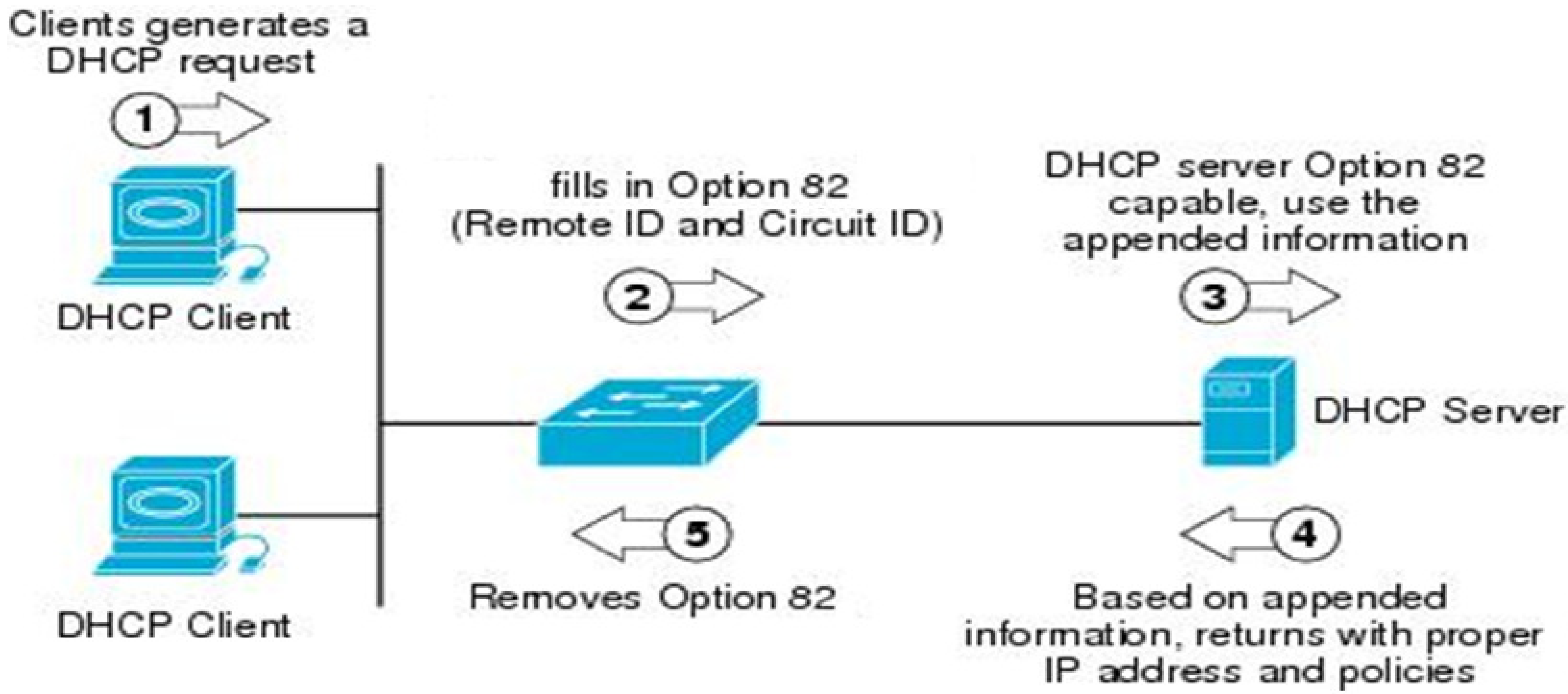
```
Switch(config)# ip dhcp snooping
Switch(config)# ip dhcp snooping vlan 10
Switch(config)# interface range gigabitethernet 1/0/35 - 36
Switch(config-if)# ip dhcp snooping limit rate 3
Switch(config-if)# interface gigabitethernet 1/0/1
Switch(config-if)# ip dhcp snooping trust
```

authentic DHCP server at interface G1/0/1

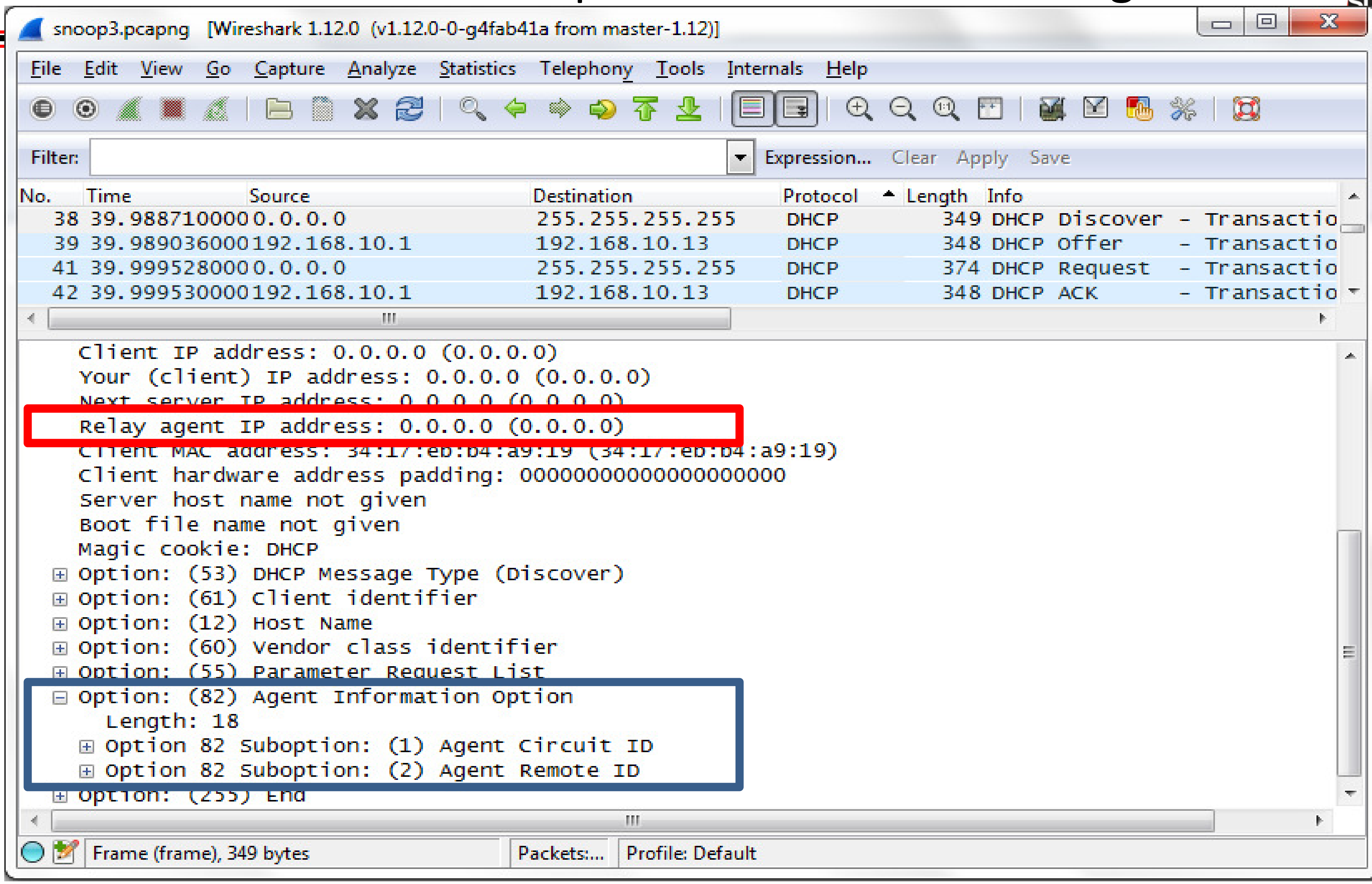
```
Switch# show ip dhcp snooping
Switch DHCP snooping is enabled
DHCP snooping is configured on following VLANs:
10
Insertion of option 82 is enabled
Interface                    Trusted     Rate limit (pps)
------------------------     -------     ----------------
GigabitEthernet1/0/35          no          3
GigabitEthernet1/0/36          no          3
GigabitEthernet1/0/1           yes         unlimited
Switch#
```

Note that by default, a switch enabled with DHCP snooping will automatically insert an option-82 (relay agent information option) field into the original DHCP messages sent by the client.

The option-82 field contains circuit ID (containing VLAN and port number) and remote ID (containing base MAC address) of the switch which provides information about location of client that sends the DHCPDiscover message.

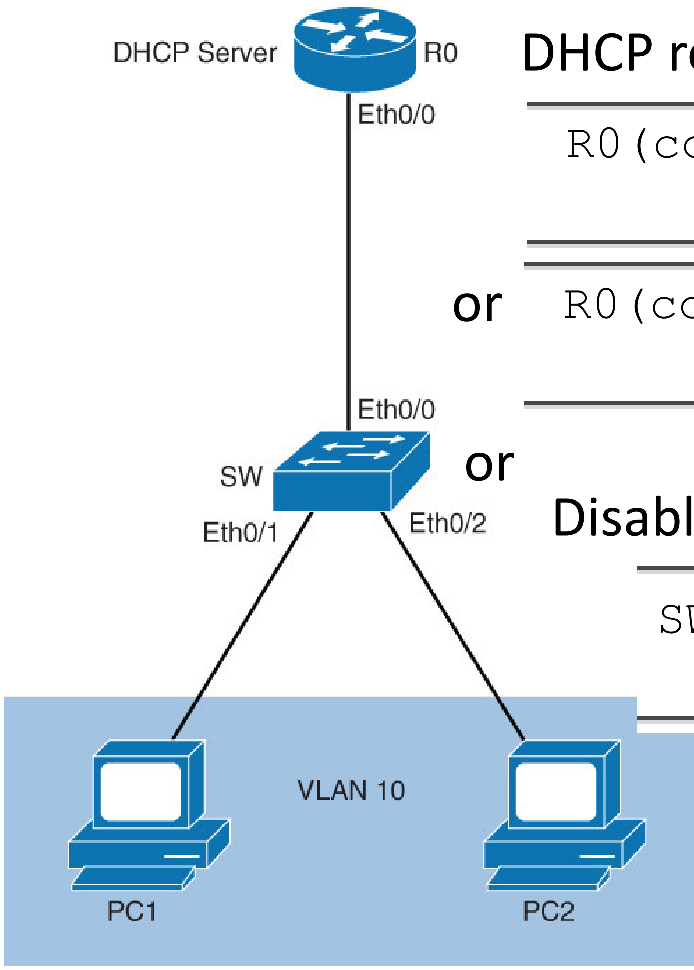


However, the switch is not a relay agent, so the relay agent IP address (giaddr) is zeros while option-82 agent field is being inserted as shown in example DHCPDiscover message below:



Unfortunately, a DHCP packet with option-82 but relay agent IP address (giaddr) zeros will by default be discarded by the next receiving DHCP relay agent/router.

To resolve this problem, configure either:



DHCP router to trust DHCP messages:

```
R0(config)# ip dhcp relay information
            trust-all
```

or

```
R0(config-if)# ip dhcp relay information
               trusted
```

or

Disable option-82 on a DHCP snooping switch:

```
SW(config)# no ip dhcp snooping
            information option
```

To support DHCP snooping, the switch also maintains a binding table containing DHCP assigned addresses for untrusted ports which can be used to defend other attacks (next exercises).

The DHCP snooping binding table is updated automatically:

- Upon seeing DHCPACK, new entry is added into binding table.
- Upon seeing DHCPNack, DHCPRelease or DHCPDecline, corresponding entry is removed.

```
SW# show ip dhcp snooping binding
MacAddress          IpAddress        Lease(sec)  Type           VLAN  Interface
------------------  ---------------  ----------  -------------  ----  ----------
00:24:13:47:AF:C2   192.168.1.4      85858       dhcp-snooping   10   GigabitEthernet1/0/35
00:24:13:47:7D:B1   192.168.1.5      85859       dhcp-snooping   10   GigabitEthernet1/0/36
Total number of bindings: 2
```